

Nathaniel Abera
September 6, 2026
Improvement Plan

A1.

NorthSound Finance had experienced a targeted phishing incident that caused one of their employees' accounts to become compromised after receiving an email that used the typosquatted domain n0rthsoundfinance.org then clicked an embedded link and entered their credentials on the attacker-controlled website at the address 203.0.113.10:8080. The main cause of this incident identified in Task 1 was a successful phishing campaign that was able to harvest an employee's credentials and deliver a payload that was written onto the employee's workstation as update.exe which established local administrative persistence with an HKLM Run key and a rogue svc_update attached to an account. The surrounding issues also included the lack of implementing an extra layer of authentication with multifactor authentication, and a lack of least privilege across user accounts, and there was also no form of email authentication. The phishing incident had put customer nonpublic financial data at risk of being compromised, and for a financial firm like NorthSound Finance they must adhere to strict rules, a compromise like this may carry heavy regulatory, financial, and reputational consequences.

A2.

After investigation, remediation was required because the compromised account had belonged to a user that had exclusive administrative privileges as it was an Identity and Access Administrator whose privileges placed customer financial data at risk of unauthorized access. If this were to be left valid any longer it would have allowed continued access to NorthSound Finance systems. Future prevention is necessary because remediation removed the attacker but not the conditions that let the attack succeed. Single-factor authentication and standing local administrator rights are still in place, so the same attack on any other employee would produce the same result.

A3.

The affected system that was identified in the phishing incident was the ORTIZ-Workstation 10.0.0.149 and the account named c.ortiz managed on the domain 10.0.0.9. The network that was affected was the internal NorthSound Finance segment which had outbound traffic that was routed to the attacker's host 203.0.113.10. The data at risk was the user c.ortiz's authentication credentials as well as customer nonpublic financial data. After further investigation there was no lateral movement detected, no other compromised accounts, and no changes to the Active Directory domain groups.

A4.

The Security Operations Manager, Samira Nadeem, is in charge of the response and detection processes. Both proposed improvements depend on her involvement to integrate these new security controls into the existing monitoring. The two dedicated teams that are responsible for establishing these new controls are the IT and security departments as they will configure the Group Policy, maintain the SIEM, deploy multifactor authentication, and implement most of the technical work. The Chief Executive Officer, Maya Kwon, is responsible for approving the budget for these proposals and accepting the residual risk. Her involvement is also required because the proposal carries first-year costs and affects the company's compliance position under the Gramm-Leach-Bliley Act. The end users of this proposal are the stakeholders because the implementation of these improvements will change how they will be able to authenticate and request elevated administrative access.

A5.

Risk #1

Risk Description: The risk is that employees can still have their credentials stolen through phishing but with no security controls in place those credentials alone will grant account access because there is no second layer of authentication that is required.

Threat Source: The external attacker conducted phishing campaigns by using a typosquatted sender domain.

Vulnerability: A single layer of authentication across all domain accounts, including privileged accounts. A valid password on its own is enough to log in.

Potential Impact: Unauthorized access leads to compromising customers' nonpublic financial data which leads to a violation of the Gramm-Leach-Bliley Act and could lead to further incidents in the future if continued. A breach of this data would also carry operational, financial, and reputational fallout for the company beyond the cost of the technical response.

Likelihood Assessment: High. Phishing is a common and recurring attack method, and this incident demonstrated that employees will click malicious links and enter their credentials. The only controls in place are user awareness and helpdesk reporting, and neither prevented this compromise. No multifactor authentication exists, so nothing will stop a stolen password from being used.

Severity Assessment: High. The account that was compromised had held Identity and Access Administrator privileges, which gives an attacker direct access to customer financial data and the ability to modify access permissions for other users as well as other vital access within the domain.

Risk #2

Risk Description: The standard user continues to hold local administrator rights on their own workstations which allows an account that was compromised to give an attacker administrative privileges.

Threat Source: Malware and obtaining access to a compromised user's account

Vulnerability: A standard user holding local administrator membership which violates least privilege rights and it allows for any standard user to permit the installation of software, registry key changes, and additional account creation.

Potential Impact: The installation of malware, the creation of unauthorized local accounts, and the disabling of security controls which had occurred in the phishing incident.

Likelihood Assessment: Medium. An attacker would've compromised an account first for this to happen so the likelihood of this happening again is less likely than in Risk #1. However, nothing is implemented to prevent local administrator rights for standard users and no alerting system currently exists when a user is added to the local Administrators group which means if an account gets compromised there would be no alert system in place that would alert the necessary team to investigate further and the attacker would be able to gain elevated access within the company's domain.

Severity Assessment: High. Local administrator access allows an attacker to stay on the machine for a prolonged amount of time, turn off any security tools, and change the system's settings. These changes are difficult to detect and correct, so the compromise would last longer and cost the company more money and staff time to remediate.

Literature Support and Analysis: The risk analysis follows the NIST Special Publication 800-30 Revision 1, which treats risk as a combination of how likely a threat is to exploit a weakness and how much harm that would cause. It also provides the Low, Medium, and High ratings used above (Joint Task Force Transformation Initiative, 2012). It says that an assessment should be naming the threat source, weaknesses that the threat could exploit, and rate the likelihood and impact individually instead of combining them into one rating, which is the exact order that had

been followed. It also says that it should be measured against the data, operations, and people involved, which is why the impacts also covered things such as compliance and regulatory obligations, customer data exposure, and the cost of responding.

A6. The objectives of this proposal are to prevent the recurrence of the incident and reduce the likelihood of it happening again as described in part A1 by eliminating the conditions that would allow for it to succeed. To strengthen the security of NorthSound Finance, ensuring the remediation and prevention procedures are implemented is recommended. This will allow for strong security controls and will keep the company in compliance with the Gramm-Leach-Bliley Act Safeguards Rule.

B1. The NorthSound Finance firm should be implementing the two security improvements to prevent the phishing incidents from occurring again as it was described in part A1. The first is adding multifactor authentication across all the accounts within the domain. The second would be enforcing the usage of least privilege which will only have specific users with the Administrator privileges and it will remove all other standard users from holding these privileges.

B2.

The multifactor authentication addresses the first risk in A1 as a single factor authentication allows for stolen credentials to be the only necessary information needed to grant an account access. The user c.ortiz had submitted valid credentials on the attacker's hosted website at 203.0.113.10:8080. Since there was no second factor required those credentials were all that was needed to log in but if a second layer of authentication was added it would prevent this.

The least privilege enforcement addresses the second risk in A1, which is that a standard user should not be holding local administrator rights. Because the attacker had those rights he was able to write update.exe, add a rogue svc_update account to the local Administrator group, and create an HKLM Run key. A standard user shouldn't be able to have this level of access which is why least privilege enforcement must be implemented as it only gives this level of access to specific users. Multifactor authentication directly protects confidentiality by keeping unauthorized users out of customer financial data, and least privilege enforcement protects integrity by making it harder for attackers to change any of the system settings or create accounts within it.

B3.

Both of the improvements would integrate with the current environment very well. The Active Directory in NorthSound Finance already runs and is active but neither of the improvements

require replacing the infrastructure so it's not necessary to create a new one and you can still use the existing one. The Multifactor authentication would be added within the domain controller DC01 at 10.0.0.9 and it will allow a broker that connects to Active Directory so that other account groups stay as they are. Any further authentication events would be sent to the Elastic/Kibana SIEM at 10.0.0.105.

The least privilege being enforced would be delivered through the Group Policy from the same domain controller DC01 which controls the local Administrators group members across the entire domain workstations. Both the Windows and Active Directory features are native so no extra software is needed and any changes to the local Administrator members list would also be logged into the SIEM which is the alerting that was missing when svc_update was added.

B4.

The first recommendation about multifactor authentication aligns with the regulatory compliance of Gramm-Leach-Bliley Act Safeguards Rule as it requires institutions to use MFA for any user account within the company that has access to information systems and it requires to limit access of customer data to authorized users (Federal Trade Commission, n.d.). The multifactor authentication meets the first requirement and least privilege enforcement meets the second. Both also align with NIST Special Publication 800-53 Revision 5 where multifactor authentication implements control IA-2 and the least privilege enforcement implements controls AC-2 and AC-6 (Joint Task Force, 2020).

B5.

The multifactor authentication is appropriate and feasible because it allows users to connect to the existing domain normally without the need of new hardware. An alternative that could be considered was using stronger password policy with complex requirements and a fixed rotation period. But this was rejected as it still allows stolen credentials to be used and valid even with a rotation period, as it still gives the attacker adequate time to do things. The multifactor authentication was the best solution as it requires another form of authentication before logging in.

The least privilege enforcement was also appropriate and feasible because it uses the Group Policy which is already within the environment and it costs nothing else to continue licensing. The alternative that was considered was deploying a new detection and response tool but this was rejected as a primary control because it simply only detects rather than prevents. As seen with the update.exe during the phishing incident it was able to write a Registry Run Key and create a rogue admin account before anyone was able to review the activity. By implementing least privilege it allows for those actions to completely stop working at all and it costs nothing.

B6.

The table below shows the first year estimates for NorthSound Finance based on 75 employees and five of those employees have privileged accounts with personnel and maintenance costing a rate of \$75 per hour.

Recommendation 1: Phishing resistant multifactor authentication

Category	Item	Cost
Hardware	FIDO2 security keys for just 5 users with privileges at \$25 each	\$125
Software	A cloud hosted MFA that integrates with the existing DC01 domain controller.	\$0
Licensing	75 user licenses will cost \$2.5 per month	\$2,250/year
Personnel	40 hours for setting up the framework for the SOC team and an enrollment phase for new members	\$3,000
Maintenance	3 hours a month of policy reviewing and enrollment support	\$2,700 / year
Total	First year cost	\$8,075

Recommendation 2: Least privilege being enforced

Category	Item	Cost
Hardware	None since it uses the existing DC01 domain controller and the current workstations	\$0
Software	Group Policy and Windows LAPS both native to the existing Windows environment	\$0
Licensing	None since it is covered by the current existing Windows Server and Active Directory licensing	\$0
Personnel	48 hours spent on the design of the Group Policy, phased rollout, and the application testing	\$3,600
Maintenance	2 hours a month will be spent on the elevation of admin privilege requests and reviews of exceptions for certain users	\$1,800

Total	First year costs	\$5,400
-------	------------------	---------

C1.

Multifactor authentication requires the IT and security teams. The Security Operations Manager will oversee the integrations and have continuous monitoring. The needed technology is the main domain controller, DC01, FIDO2 security keys, a cloud hosted multifactor authentication, and five user accounts with privileged access. The tools needed for this implementation are Active Directory Users and Computers for group management and the Elastic/Kibana SIEM at the address 10.0.0.105 for logging the authentication events when they happen. As for the stakeholders, there are going to be specific resources such as the CEO Maya Kwon's approval about the budget and the enrollment time that it will take to be completed.

The least privilege enforcement will require this same IT and security team with an additional helpdesk staff that handles the requests for elevation if a user's admin privileges are removed. As for the technology that is needed, the Group Policy and the Windows LAPS are both native to the existing Windows environment and are applied from the DC01 domain controller. The tools that are included are the Group Policy Management Console and the SIEM which is for logging any of the changes to the local Administrators member list. The stakeholders will be provided additional resources that include an inventory of applications from the managers that will identify what software is currently required for admin rights.

C2.

The multifactor authentication depends heavily on a few prerequisites. The NorthSound finance must select an MFA vendor that will host their services and ensure that it supports the institution with the existing Active Directory as well as budget approval which must be approved before purchasing licensing. The external factors include the delivery times of the FIDO2 keys from the vendor and the number of employees with mobile devices for users to implement the MFA.

The least privilege enforcement also heavily depends on a key thing as well which is the application inventory because it removes admin rights which has the possibility of breaking the software that is currently being used. By establishing a helpdesk staff to evaluate the processes before they roll out the users will not be locked out of any legitimate tasks. The external factors include the vendor's estimated delivery timelines for any application.

C3.

A potential challenge that multifactor authentication may face is that a user could fail to enroll in MFA and this delay could cause employees to only have a single factor authentication for a set

amount of time until they actually do it. So this may lead to lockouts or an increased volume of helpdesk tickets until they get adequate with the MFA setup.

A potential challenge for the least privilege enforcement is that the application could break and it would lead to a removal of a local administrative users right which may stop the software from running and it could interrupt daily work within the departments that are affected.

C4.

The enrollment challenge that the company may face when it is implemented could be mitigated by initiating the rollout by beginning with the five user privileged accounts and the SOC team then start rolling it out to the other employees in other departments. By focusing on these main employee departments it will reduce lockouts and the helpdesk would be able to allow for an increase of volume during the enrollment window while keeping the SOC team and the administrative users enrolled.

The breakage that the least privilege enforcement challenge may face could be mitigated by finishing the application inventory before rolling it out and testing the Group Policy in groups. This way an application confirmed to require elevation would be granted a documented exception through the helpdesk elevation process rather than restoring standing admin rights.

C5.

Phase	Multifactor Authentication (MFA)	Least Privilege
Design	It would take about 1 to 3 weeks to choose a vendor that will host the cloud service, confirm the Active Directory, and ensure that the enrollment groups and policies are defined.	The first 1-4 weeks will consist of completing the inventory of the application, ensure that the Group Policy is designed, and the elevation request process has been properly defined
Testing	The first 4 to 6 weeks will focus on getting the SOC team enrolled as well as the five privileged user accounts, and lastly verify that the SIEM is properly logging	The first 5 to 8 weeks will apply the policy to group workstations and document required exceptions that

		may be needed
Deployment	The weeks 7-10 will be phased on the rollout of enrollment for the rest of the departments and distribute hardware keys	The weeks 9 through 12 will focus on rollouts of enrollment by department and remove current local admin rights
Monitoring	The weeks 11 to 16 will review authentication logs and the failed attempts with every quarter being a policy review	The weeks 13 to 16 will consist of ensuring that the alert systems of the local Administrator group changes are working and that the monthly exception reviews will be completed

D1.

NorthSound Finance will continue to monitor any signs of similar threats by using the Elastic/Kibana SIEM at 10.0.0.105 which already collects authentication and endpoint logs, just as the tool was used to trace the attack chain during the original incident. The detection will be able to cover both of the risks that were identified in A1. As for the risk of credential theft the SIEM will be able to collect the events made with multifactor authentication from the domain and automatically alert any repeated failed attempts which will indicate that an attacker is attempting to use a stolen password. For the privilege risk the workstation logs within the SIEM will alert any changes that are being made to the local Administrators group which is what happened when the svc_update account was created during the phishing incident. Any reported phishing emails from the helpdesk will be logged and any repeated attempts will be visible to the team at all times. Management will also track a target of 98% multifactor authentication (MFA) enrollment across all of the domain accounts along with a defined response time for SIEM alerts on changes to the local Administrator groups.

D2.

The organization will be able to maintain the effectiveness of multifactor authentication by ensuring that the platform handles any patches and updates to its cloud hosted service regularly.

The company NorthSound Finance will continue to review the enrollment records quarterly to confirm that every account has an active second factor. The policies of authentication will also be reviewed every year.

The least privilege enforcement will also be maintained by ensuring Windows processes are patched regularly and things such as the Group Policy and the Windows LAPS are being updated within the operating system rather than separately. The dedicated IT team will also review the local Administrators group members on a monthly basis to confirm that there are no unauthorized accounts that have been added and they will be documenting the review as well as any elevation exceptions that had been made every quarter.

D3.

The incident response of readiness will improve by having two procedures set. If a solution fails such as if the multifactor authentication service becomes unavailable for whatever reason the SOC team will follow a documented emergency access procedure that allows temporary access to a limited number of accounts with additional logging for this kind of event. If the Group Policy fails to apply and local administrator rights return to a workstation, the SIEM will alert on the change to the Administrators group, which triggers a review and the policy is reapplied.

If a system is compromised the existing SOC department will initiate the incident response plan, which will be updated to reflect the new controls. The containment steps of the account would be the next step as well as resetting and disabling the account, then revoking any registered second factor authentication so that the attacker can't re-enroll. This containment will also continue to do the other necessary steps such as eradication to remove the update.exe and other persistence as demonstrated in the phishing incident.

E1.

Other than the two recommendations that were made in B1, the company should implement an email authentication as well by using SPF, DMARC, and DKIM which will flag unauthenticated mail. The emerging threat is domain impersonation through lookalike domains and no email authentication was in place, which had allowed for the attacker to use the domain n0rthsoundfinance.org to reach the employee inboxes. Future implementation should automatically reject any unauthenticated domain sender addresses and block them from entering an employee's inbox. The containment and eradication steps that were commenced had followed the incident handling phases as described within the NIST Special Publication 800-61 Revision 2 (Cichonski et al., 2012).

E2.

The mitigation that would be approached is publishing the SPF, DMARC, and the DKIM records to the NorthSound Finance domain and have the DMARC policy set to reject then add any typosquatted domains that are not from the institution on the blocklist. This is the best and appropriate way of preventing random addresses from entering the domain and it is a free DNS record that can be updated with no costs. Expected effectiveness is high against spoofed mail and partial against lookalike domains, which email authentication cannot block on its own.

E3.

The employees should also be receiving training on how to identify lookalike sender domains and how to spot phishing emails. They should also be trained by using phishing simulations that will be able to train their muscle memory on how to identify and report suspicious mail to the helpdesk when found.

F1.

The multifactor authentication helps reduce risk by not having users' credentials be the only layer of protection when logging in. It adds a second layer of security, and it lowers the risk of a compromised account as stated in A1 from high to low. The least privilege enforcement also has its risk reduced by removing any of the elevated access an attacker would need to install malware. By preventing standard users from having admin access, it limits any future compromise to the user's own profile rather than the whole workstation.

F2.

The performance is unaffected because these controls both run through the current infrastructure without needing to change any of the systems or workstations. The only time efficiency might drop is when the rollout happens and users begin enrolling which will increase the volume of helpdesk tickets but once this is complete it will normalize and everything goes back to normal operations. The user experience will change in two ways. Employees will have added a second step at the login and it will also task administrators that have current rights to go through the help desk to make requests rather than them being able to do it directly themselves.

F3.

The first impact that the business would have is an improved regulatory standing since multifactor authentication is a direct Gramm-Leach-Bliley Act Safeguards Rule requirement that the company does not currently meet. The second one is protecting the trust of their customers, because a breach of customer nonpublic financial data would carry reputational damage that remediation alone cannot fix. The third is to lower costs of incident response since preventing a

compromise will save the SOC team many hours of work and it will also keep the helpdesk focus on other mundane tasks.

G.

The NorthSound Finance firm has faced two ongoing risks that need to be resolved with implementation of improvements that will benefit the future of the company. The single factor authentication makes it very easy for stolen credentials to be used by attackers once obtained and allowing standing local administrator rights let a compromised account create persistence on a workstation, such as writing malware and adding a rogue administrator account. By implementing multifactor authentication and least privilege enforcement on administrative user accounts this will resolve both of these issues and the most important factor of this is that it meets the Gramm-Leach-Bliley Act Safeguards Rule and it prevents the compromising of other accounts to spread and the compromise of customer nonpublic financial data, which would cost the firm far more than either of these controls being implemented.

References

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). Computer security incident handling guide (NIST Special Publication 800-61 Revision 2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>

Federal Trade Commission. (n.d.). Gramm-Leach-Bliley Act. <https://www.ftc.gov/business-guidance/privacy-security/gramm-leach-bliley-act>

Joint Task Force. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Revision 5). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-53r5>

Joint Task Force Transformation Initiative. (2012). Guide for conducting risk assessments (NIST Special Publication 800-30, Revision 1). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-30r1>

Appendix A

Figure 1 - Phishing email from n0rthsoundfinance.org sender domain with the link to 203.0.113.10:8080 that leads to the attacker's host website containing the survey.

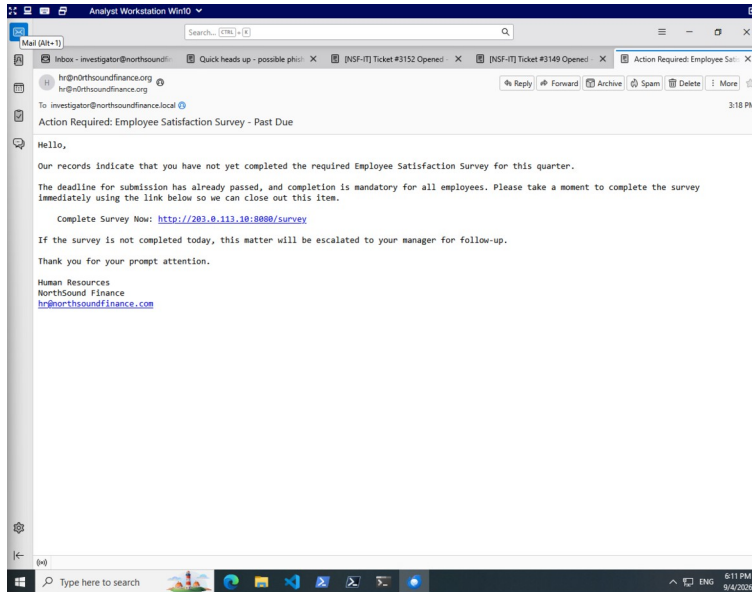


Figure 2 – Email header showing the sender domain within Thunderbird and the absence of any authentication results within the data. This relates to sections A1 and E1.

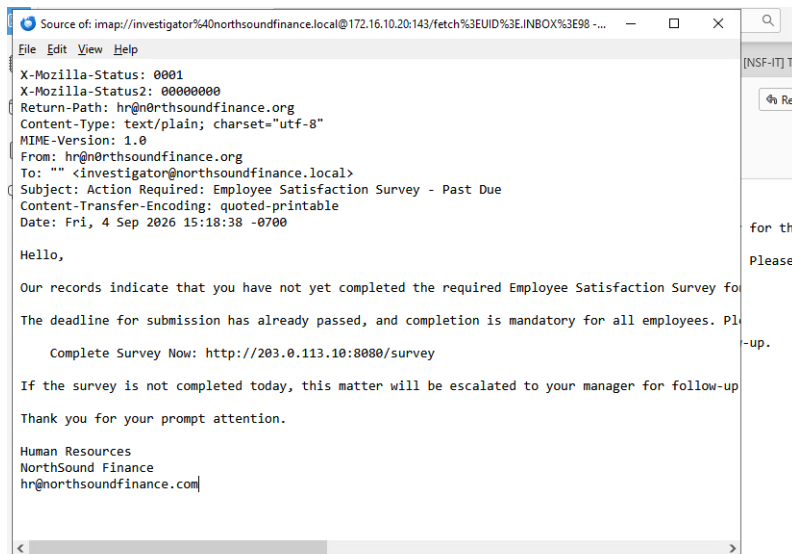


Figure 3 – The SIEM attack chain showed that the submissions of the credentials were made to the address 203.0.113.10:8080, a stager download, and the update.exe being written onto ORTIZ-Workstation. This supports A1.

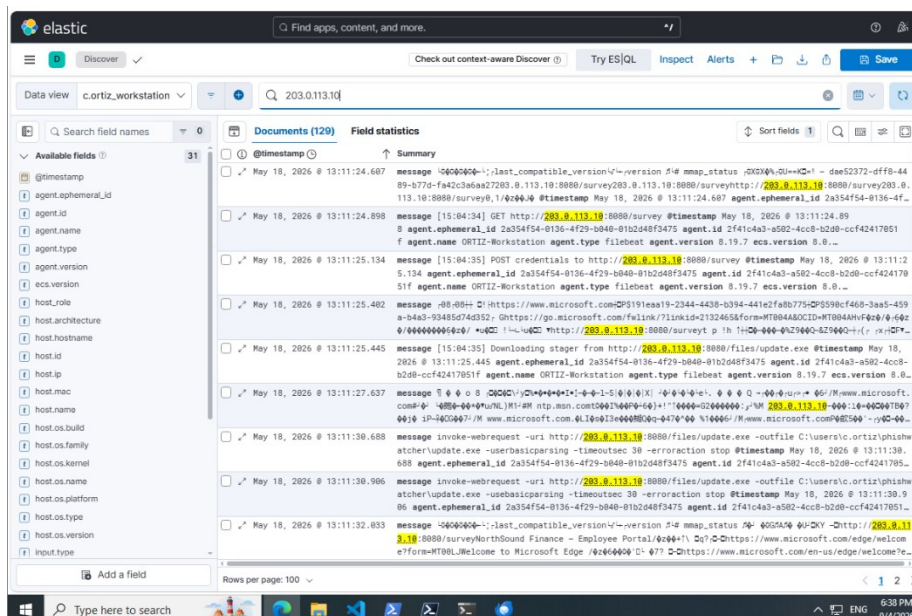


Figure 4 – This details the rogue svc_update found to be attached to an account that had admin privileges and showed as a member within the local Administrators group. This supports A5 Risk #2 and B2.

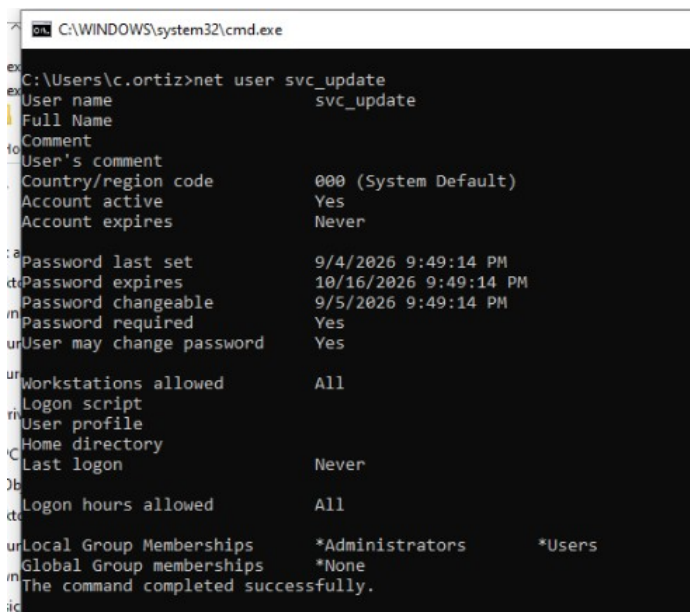


Figure 5 – The helpdesk ticket #3149 had documented that the reported phishing incident had occurred. This supports A5 Risk #1.

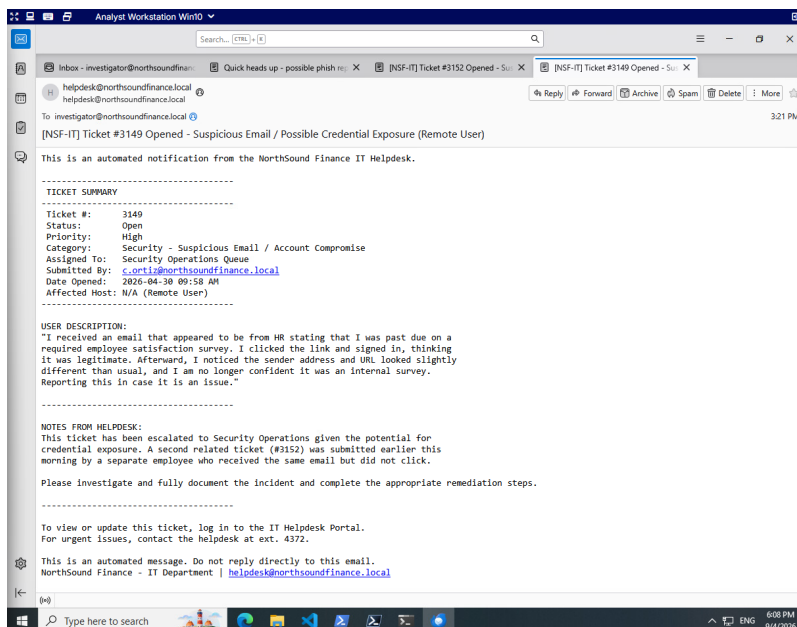


Figure 6 – The lab had been completed and Security Operations Manager, Samira Nadeem, had sent an email confirmation which verifies that the Workplace Experience Lab had officially been completed.

